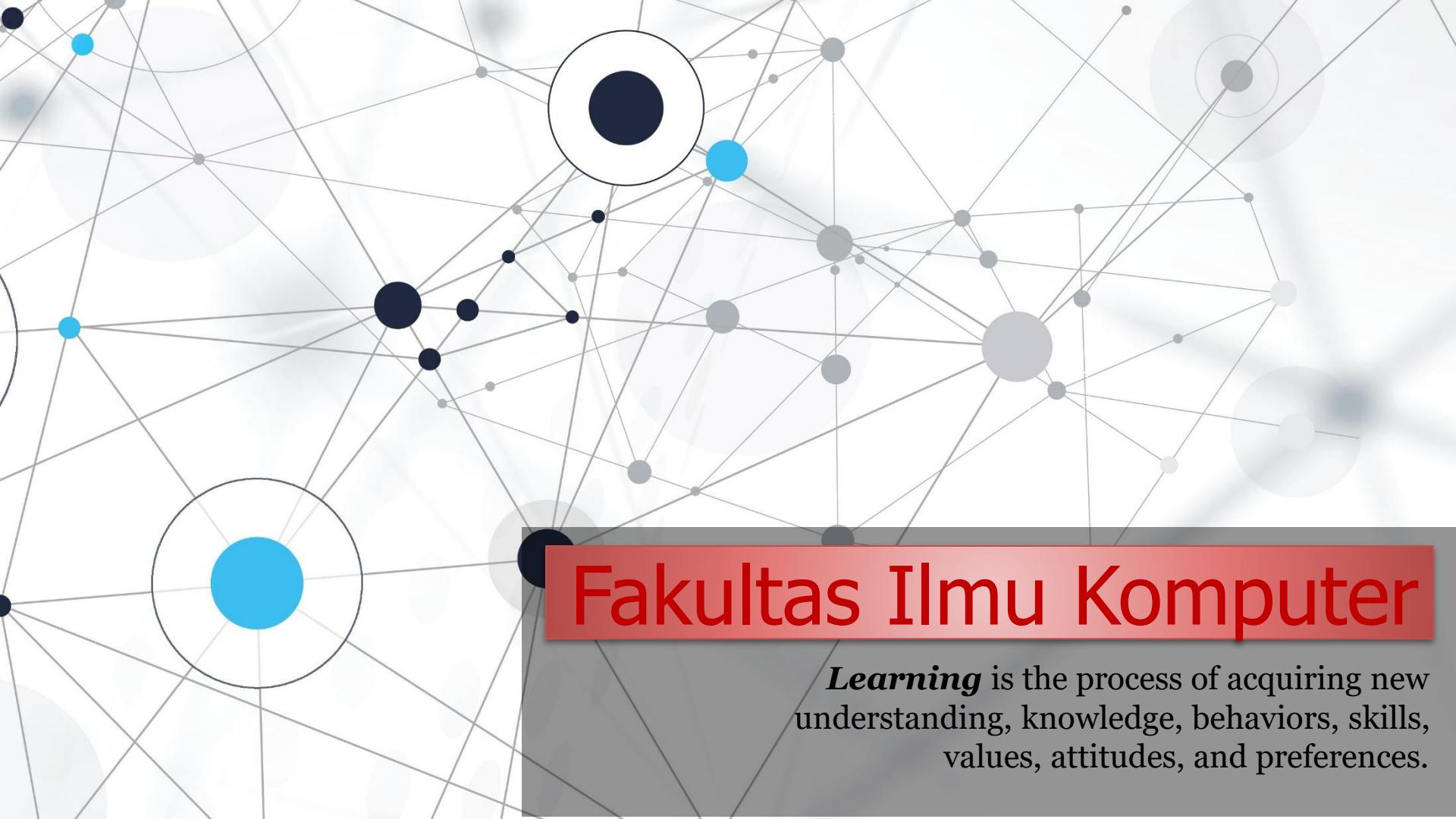


An abstract network diagram with various sized nodes (black, blue, grey) connected by thin grey lines. Some nodes are highlighted with larger circles. The background is white with faint grey circles.

Fakultas Ilmu Komputer

Learning is the process of acquiring new understanding, knowledge, behaviors, skills, values, attitudes, and preferences.

Enhancing Website Security Through **The Role of Firewalls & SSL Certificates**



A decorative border of green leaves and branches at the top of the slide.

1 - Security *in* Website

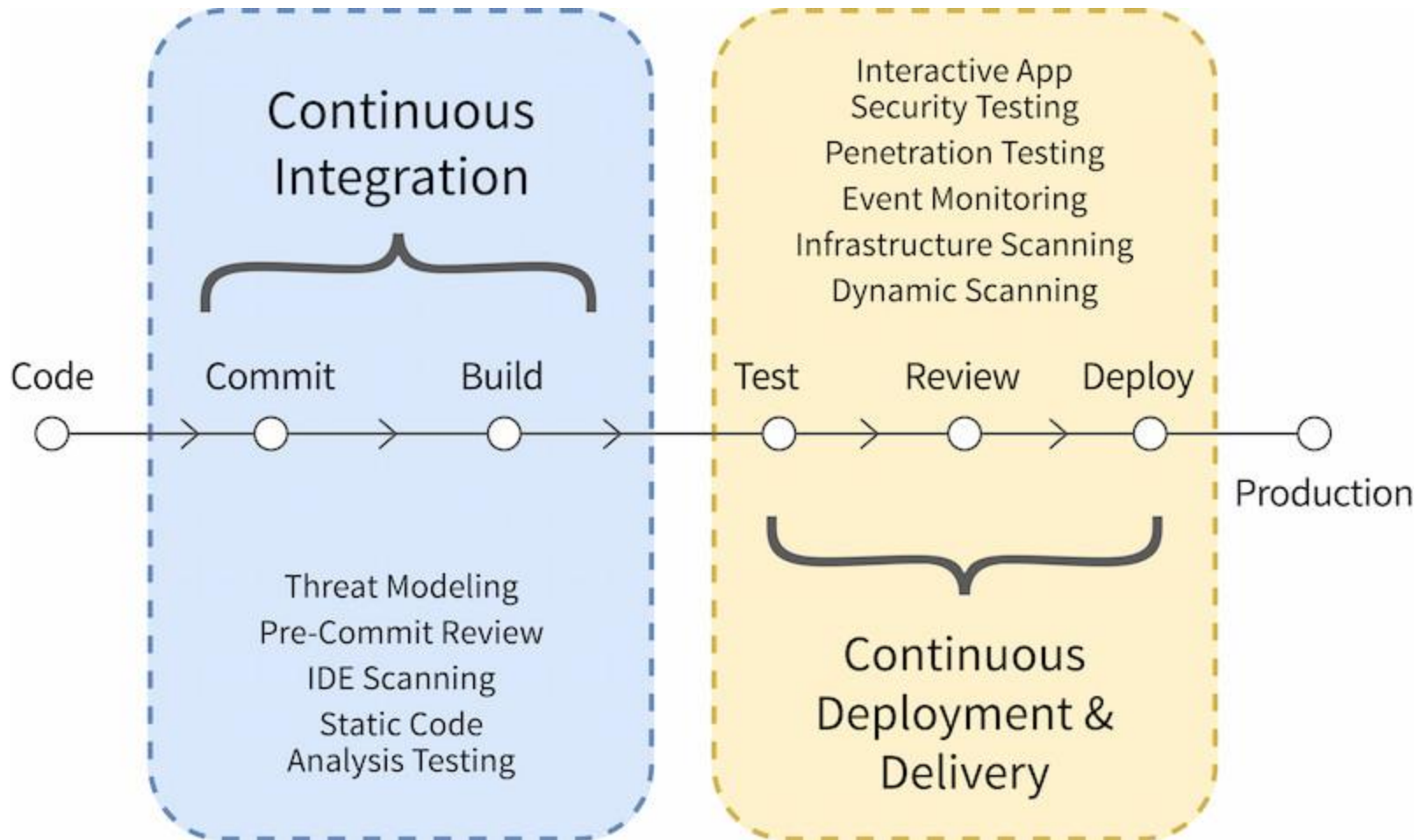
A decorative border of green leaves and branches at the bottom of the slide.

Understanding *the* Challenges

Dalam hal mengintegrasikan keamanan ke dalam proses operation, organisasi menghadapi beberapa tantangan. Salah satu rintangan utama adalah pergeseran budaya yang diperlukan untuk memprioritaskan keamanan di samping kecepatan (*speed*) dan efisiensi (*efficiency*). Misalnya, *developers* mungkin berfokus pada rapid code deployment (*penyebaran kode yang cepat*), dan secara tidak sengaja mengabaikan **potensi kerentanan keamanan** (***potential security vulnerabilities***). Untuk mengatasinya, companies perlu mengembangkan budaya yang menekankan pentingnya keamanan di setiap langkah proses pengembangan.

Vulnerability scanning is a fundamental practice in maintaining a secure website environment. Consider an automated vulnerability scanning tool that continuously analyzes your software and infrastructure for potential weaknesses.





Tahap coding dalam pengembangan sistem atau aplikasi sebenarnya **hanya tahap awal saja** terdapat beberapa tahapan dalam siklus pengembangan perangkat lunak secara keseluruhan.

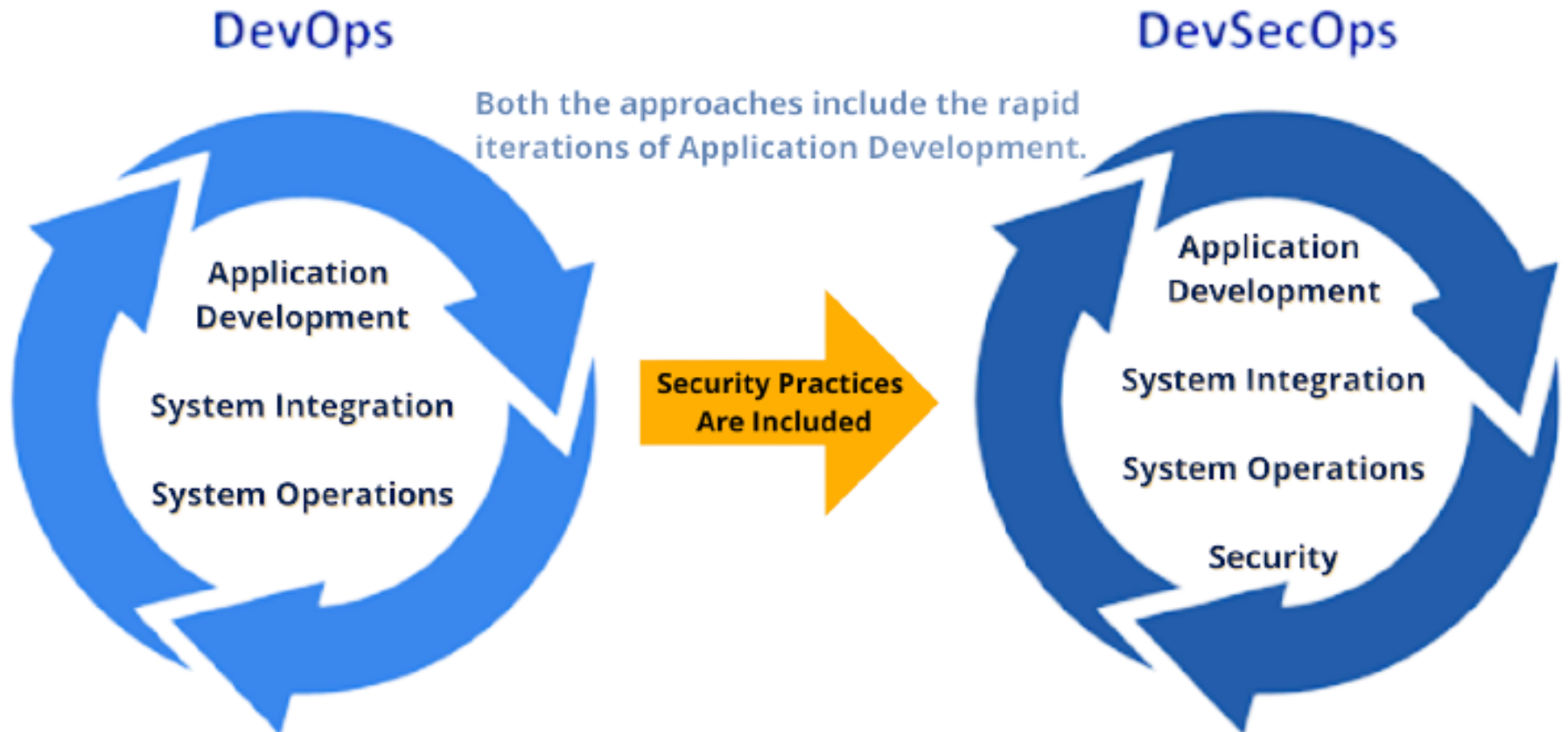
Siklus ini dikenal sebagai Software Development Life Cycle (SDLC) atau siklus hidup pengembangan perangkat lunak. Tahapan coding biasanya disebut sebagai implementasi dan merupakan bagian dari tahapan yang lebih besar.

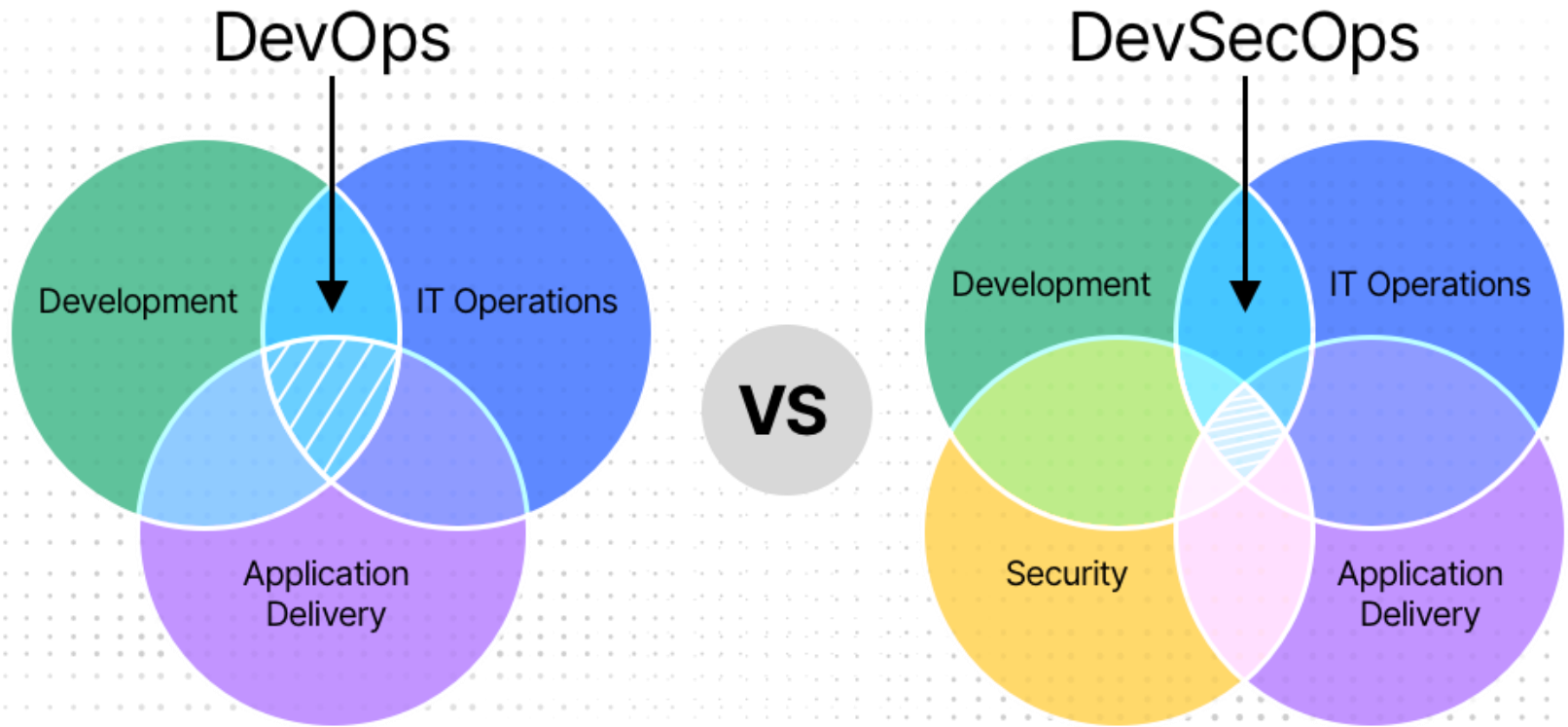
What is website security?

- ❖ The **Internet is a dangerous place**. With great regularity, we hear about websites becoming unavailable due to denial of service attacks, or displaying modified (*and often damaging*) information on their homepages.
- ❖ There are **three main types of Web server security**: (1) physical, (2) network and (3) host. All network connections are protected by a firewall, a hardware or software component that prevents unauthorized access to or from a network. Web Server Security encompasses two major areas: The security of the data on the web server.
- ❖ The **purpose of website security** is to prevent these (*or any*) sorts of attacks. The more formal definition of website security is the act/practice of **protecting websites from unauthorized access, use, modification, destruction, or disruption**.
- ❖ **If a web server is secure, it means that only authorized users have access to protected information**, and that the **integrity of information** provided to website users is safeguarded.

DevOps vs DevSecOps

DevSecOps (**Development**, **Security** and **Operations**) is a process of implementing security practices and actions in the DevOps lifecycle. It's all about embedding security features and enhanced automation throughout the CI/CD pipeline for removing mistakes and reducing attacks & downtime.

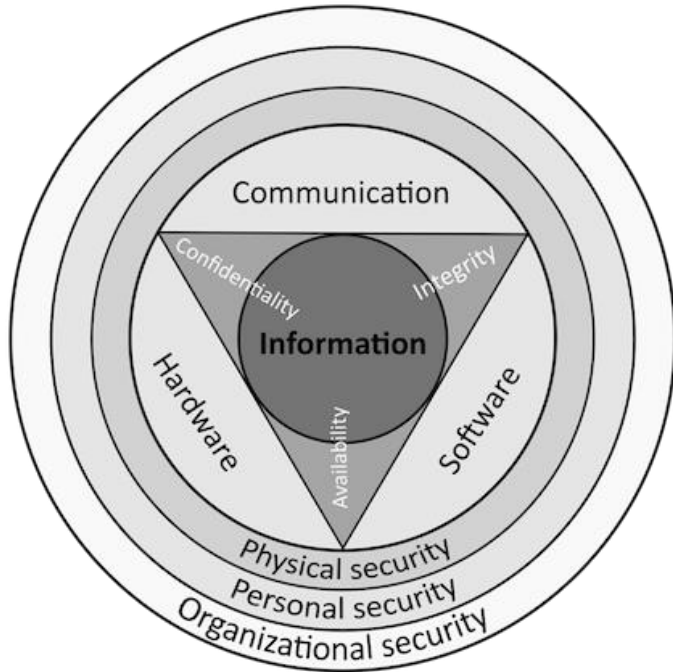




The goal of DevSecOps is to bridge the gap between IT and security by adding *security practices* to the already fast and agile software delivery process. Organizations using the DevSecOps model understand that security cannot be considered at the end of the delivery pipeline, so they make it an integral part of the entire software development lifecycle (SDLC).

Three Aspects of Security

A web server can be configured to handle three facets of security:



Availability, by enabling rate limiting to protect business application server compute resources from DDoS attacks

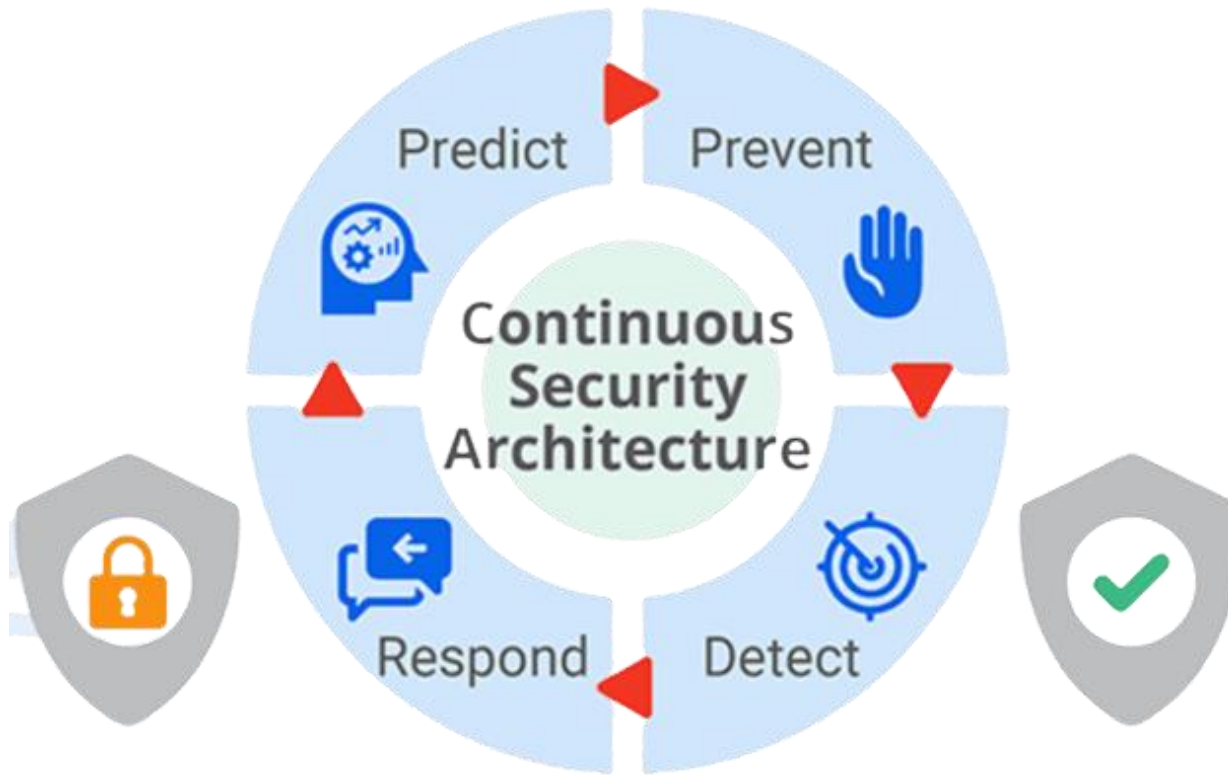
Confidentiality through:

Client Authentication, or AuthN, by prompting a user to provide a username and a password to associate with a principal in a network

Client Authorization, or AuthZ, by ensuring certain URLs are protected from anonymous access and requiring association with a principal to obtain access

Integrity and **Trust**, by using HTTPS, TLS certificates, and Public Key Infrastructure (PKI) to prove to users that we are who we say we are (trust), that the data passed between the web server and the user has not been modified in-flight (integrity), or viewed by another party (confidentiality).

Security is Continuous Process



Keamanan adalah proses yang berkelanjutan, dan **monitoring keamanan** yang terus menerus sangat penting untuk mendeteksi dan merespons potensi ancaman (*potential threats*) secara real-time. Misalnya, sistem pendeteksi dapat terus memantau lalu lintas jaringan (*monitor network traffic*) dan memperingatkan (*alert*) tim jika terdeteksi aktivitas yang mencurigakan. Tanggapan yang tepat waktu terhadap peringatan tersebut dapat mencegah atau meminimalkan dampak insiden keamanan.

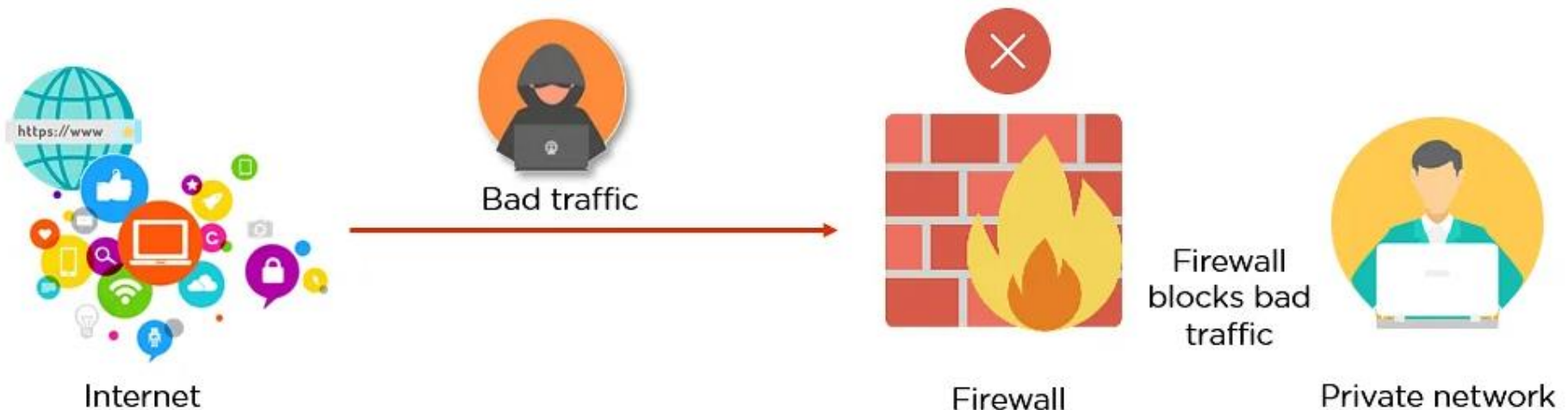
A decorative border of green leaves and branches at the top of the slide.

2 – Firewall & SSL *in* Cloud Server

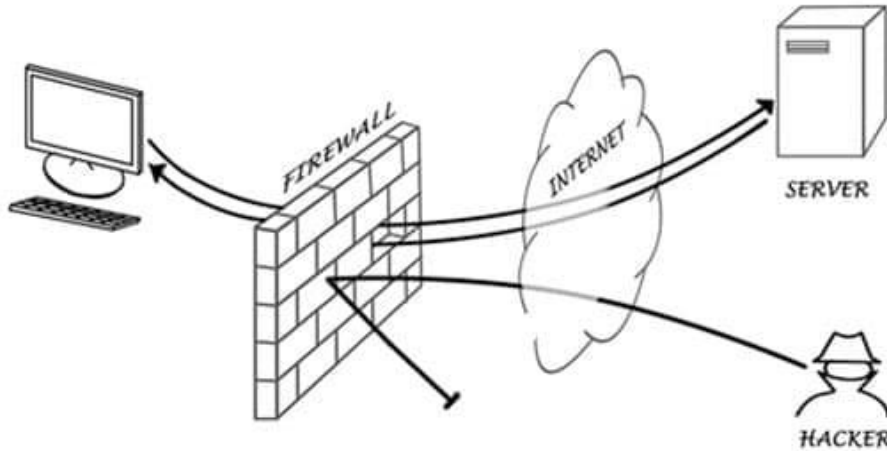
A decorative border of green leaves and branches at the bottom of the slide.

Firewall *in* Cloud Server

Dengan meningkatnya jumlah *cybercrimes* (*kejahatan siber*) setiap harinya, *personal* dan *companies* harus mengamankan informasi mereka. Namun, ada banyak tantangan untuk menerapkan hal yang sama. Firewall adalah salah satu perangkat keamanan yang dapat membantu melindungi jaringan dan perangkat kita dari pihak luar.



Why Firewalls Important?



Firewalls are an important part of the security architecture **to protect systems and data from threats** that may come from the internet or internal networks. In the context of **DevOps**, the use of firewalls is still very relevant and important.

- ❖ **Firewalls** are designed with **modern security techniques** that are used in a wide range of applications.
- ❖ In the early days of the internet, **networks needed to be built with new security techniques**, especially in the client-server model, a central architecture of modern computing.
- ❖ That's where firewalls have started to build the security for networks with varying complexities. **Firewalls are known to inspect traffic and mitigate threats to the devices.**

Advantages of Using Firewalls

- 1) Firewalls play an important role in the companies for security management. Below are some of the important advantages of using firewalls.
- 2) Firewalls provide enhanced security and privacy from vulnerable services. It prevents unauthorized users from accessing a private network that is connected to the internet.
- 3) Firewalls provide faster response time and can handle more traffic loads.
- 4) A firewall allows you to easily handle and update the security protocols from a single authorized device.
- 5) Firewall safeguards our network from **PHISHING ATTACKS**.
- 6) **Phishing attacks** are a form of cyberattack carried out with the intention of obtaining personal or financial information from the victim. The main goal of a phishing attack is **to steal sensitive information** such as passwords, credit card numbers, bank account information, or other identifying information.

Vulnerabilities (Kerentanan)

Insider Attacks



Insider attacks involve activities such as the transmission of sensitive data in plain text, resource access outside of business hours, sensitive resource access failure by the user, third-party users' network resource access, etc.

Distributed Denial of Service (DDoS) Attacks



Distributed denial of service (DDoS) attack is a malicious attempt to disrupt normal traffic of a targeted network by overwhelming the target or its surrounding infrastructure with a flood of traffic. The DDoS attack is used to mitigate the difference between an attack and normal traffic.

Malware



Malware threats are usually difficult due to their varied, complex, and constantly evolving nature. These days, with the rise of IoT, networks are becoming more complex and dynamic so that sometimes it becomes difficult for firewalls to defend against malware.

Patching/Configuration



Patching/Configuration is a firewall with a poor configuration or a missed update from the vendor that may damage network security. IT admins need to be very proactive concerning their maintenance of security components.

Uncomplicated Firewall (UFW)

- ❖ UFW and Iptables are related because UFW is essentially a simpler interface for managing Iptables. UFW is just a frontend for iptables to make it easier to manage.
- ❖ Iptables and UFW both are Linux system firewalls, the difference between them is UFW is built upon Iptables, Iptables a very flexible tool but it's more complex as compared to UFW, other difference is that Iptables requires a deeper understanding of TCP/IP, which might not be the case with every Linux user, so UFW is the solution, UFW allows the user to configure firewall rules easily using Iptables.
- ❖ Iptables is an extremely flexible firewall utility that was **built for Linux operating systems**. Iptables is a great tool with many functionalities that can be used to secure your Linux system from unwanted traffic. However, it can be difficult for beginners to learn how to use it properly when configuring the firewall. As a result, the UFW is well-suited for beginners.
- ❖ UFW is a great firewall tool that is designed to be run on hosts or servers. It allows or blocks incoming and outgoing connections to and from the server.
- ❖ Meskipun lebih mudah digunakan, UFW tidak memiliki kemampuan yang sama dengan iptables dalam mengkonfigurasi aturan firewall secara spesifik. Namun, UFW tetap dapat diandalkan untuk melindungi sistem dari serangan jaringan (*network attacks*).



website



https://www.



Connection is secure

■ Certificate (Valid)

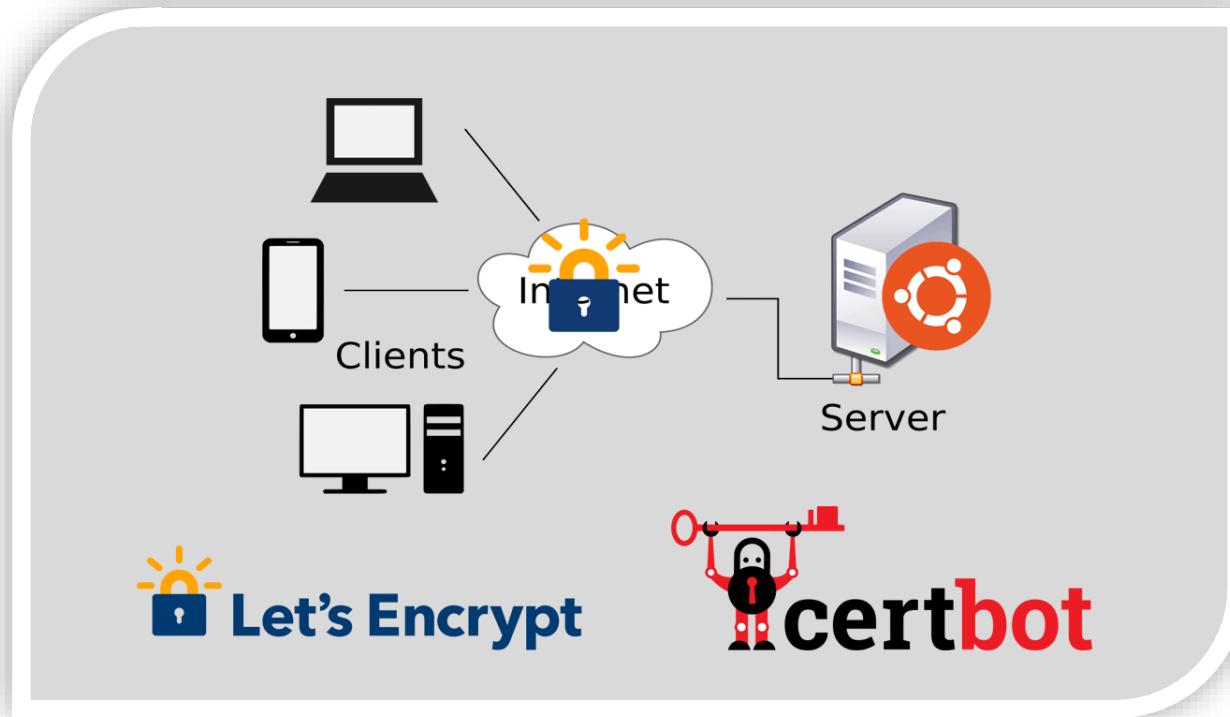
SSL certificates (Secure Sockets Layer) are what enable websites to use HTTPS, which is more secure than HTTP. An SSL certificate is a data file hosted in a website's origin server. SSL certificates make SSL/TLS encryption possible, and they contain the website's public key and the website's identity, along with related information.

How do SSL certificates work?

SSL certificates include the following information in a single data file:

- 1) The domain name that the certificate was issued for
- 2) Which person, organization, or device it was issued to
- 3) Which certificate authority issued it
- 4) The certificate authority's digital signature
- 5) Associated subdomains
- 6) Issue date of the certificate
- 7) Expiration date of the certificate
- 8) The public key (the private key is kept secret)

Let's Encrypt SSL Certificate



Let's Encrypt is a free, automated, and open certificate authority. Let's Encrypt is a global Certificate Authority (CA) to let people and organizations around the world obtain, renew, and manage SSL/TLS certificates. These certificates can be used by websites to enable secure HTTPS connections. Let's Encrypt offers Domain Validation (DV) certificates.

Perubahan arsitektur di dalam pengembangan software (SDLC ke DevOps) membuat beberapa *security experts* memperingatkan bahwa firewall memiliki peran penting untuk menjaga keamanan jaringan dalam lingkungan yang bebas risiko. Dengan demikian, pentingnya dan masa depan *firewall* tidak akan pernah berakhir. Namun, mungkin ada banyak alternatif canggih untuk firewall di masa depan.



Exercise *for* Students

A red ribbon graphic with the word "ASSIGNMENT" written in white, bold, sans-serif capital letters. The ribbon is folded and has a 3D effect with shadows.

ASSIGNMENT

Exercise #1

(Open and close ports in Ubuntu 22.04 using UFW)

What is Port *in* Ubuntu 22.04?



Di Ubuntu 22.04 atau sistem operasi Linux lainnya, istilah "*port*" adalah mekanisme yang digunakan untuk mengidentifikasi **service (layanan)** atau **proses (process)** yang berjalan di suatu sistem. Port adalah angka 16-bit yang dapat digunakan oleh protokol jaringan untuk mengarahkan data ke aplikasi atau layanan tertentu.

Common Ports *in* Ubuntu

Port 22 untuk SSH
(Secure Shell)



Port 22 umumnya digunakan untuk layanan SSH (Secure Shell). SSH memungkinkan kita untuk terhubung ke sistem jarak jauh secara aman dan melakukan administrasi atau transfer file melalui koneksi terenkripsi.

Port 80 untuk HTTP
(tanpa enkripsi)



Port 80 digunakan untuk layanan HTTP (Hypertext Transfer Protocol). HTTP adalah protokol yang digunakan untuk mentransfer data pada web. Ketika kita mengakses situs web menggunakan protokol HTTP, koneksi dilakukan melalui port 80.

Port 443 untuk HTTPS
(dengan enkripsi)



Port 443 digunakan untuk layanan HTTPS. Sama seperti HTTP, HTTPS juga digunakan untuk mentransfer data pada web, tetapi dengan tambahan lapisan keamanan menggunakan enkripsi SSL/TLS. Koneksi HTTPS menggunakan port 443.

Update Firewall Ubuntu

Mengaktifkan firewall UFW (Uncomplicated Firewall) di Ubuntu 22.04:

- **sudo ufw enable**
- **sudo ufw disable (menonaktifkan)**

Memeriksa status UFW untuk memastikan bahwa firewall sudah diaktifkan:

- **sudo ufw status**

Memblokir port tertentu (contoh port 20) pada firewall UFW:

- **sudo ufw deny 20/tcp (mem-nonaktifkan port 20)**
- **sudo ufw allow 20/tcp (mengaktifkan kembali port 20)**

Untuk mengizinkan traffic SSH (port 22):

- **sudo ufw allow 22/tcp**

Untuk mengizinkan traffic HTTP (port 80):

- **sudo ufw allow 80/tcp**

Untuk mengizinkan traffic HTTPS (port 443):

- **sudo ufw allow 443/tcp**

To only allow traffic on port 80, use the Apache profile:

- **sudo ufw allow in "Apache"**

Deny traffic port 80:

- **sudo ufw deny in "Apache Full"**
- **sudo ufw deny in "Apache"**
- **sudo ufw deny 80/tcp (for http traffic)**

In general, for Linux, ports 1-1024 can only be opened by root . Ports 1025-65535 can be opened by anyone. If you wanted to, you can use all 65535 ports for some purpose.



Jika kalian mau agar supaya unauthorized user tidak bisa akses kalian punya server, maka port berapa yang harus di tutup?



ASSIGNMENT

Exercise #2

(Change default SSH Port *in* Ubuntu 22.04)

Sebagian besar unauthorized user akan mencoba port default SSH (port 22), jadi sebaiknya pilih port lain di atas 1024, tetapi tidak boleh melebihi 65535.



A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks.

Change SSH Configuration

Ubah Konfigurasi SSH:

- **sudo su**
- **sudo nano /etc/ssh/sshd_config**

Temukan baris yang mengandung **Port 22** dan ganti dengan **Port 9765**, jangan lupa hapus tanda “#”.

Restart SSH service agar perubahan di updated:

- **sudo chmod 644 /etc/ssh/sshd_config**
- **sudo chown root:root /etc/ssh/sshd_config**
- **sudo systemctl restart sshd**

Di UFW Firewall, izinkan port baru:

- **sudo ufw allow 9765/tcp**

Uji Koneksi SSH:

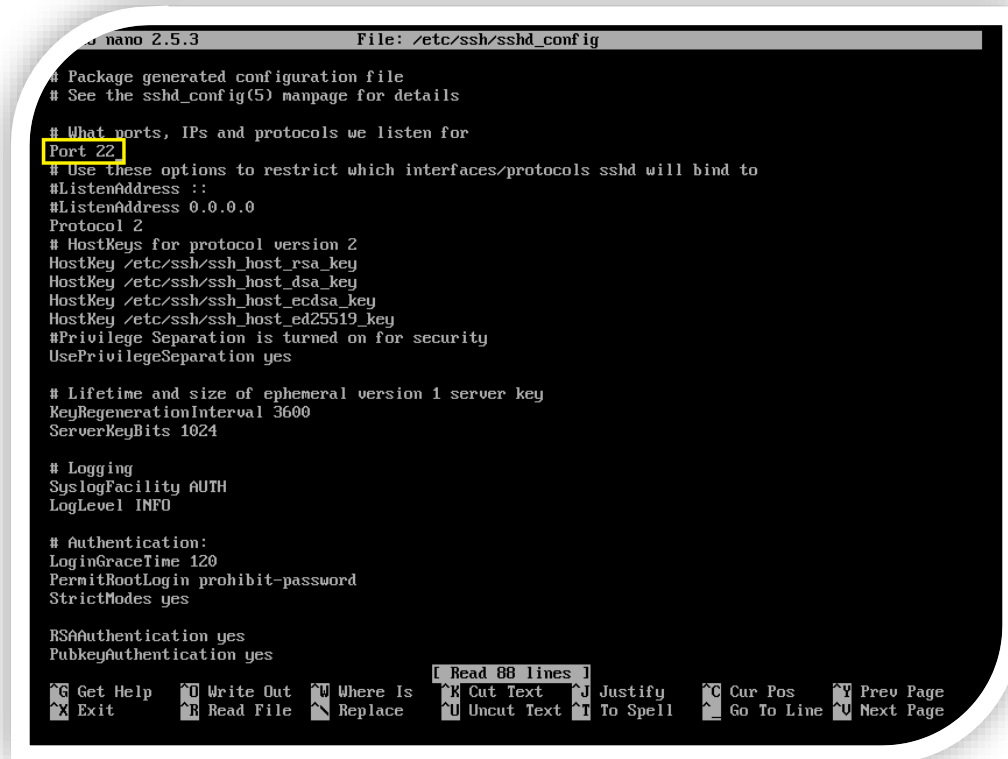
- **ssh -p 9765 username@server_ip**

Hapus Izin Port Lama (Opsional):

- **sudo ufw deny 22/tcp**
- **sudo ufw delete allow 22/tcp**

ERROR !!!

(ssh: connect to host 103.76.120.199 port 9765: Connection refused)



```
nano 2.5.3 File: /etc/ssh/sshd_config
# Package generated configuration file
# See the sshd_config(5) manpage for details

# What ports, IPs and protocols we listen for
Port 22
# Use these options to restrict which interfaces/protocols sshd will bind to
#ListenAddress ::
#ListenAddress 0.0.0.0
Protocol 2
# HostKeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
HostKey /etc/ssh/ssh_host_ed25519_key
#Privilege Separation is turned on for security
UsePrivilegeSeparation yes

# Lifetime and size of ephemeral version 1 server key
KeyRegenerationInterval 3600
ServerKeyBits 1024

# Logging
SyslogFacility AUTH
LogLevel INFO

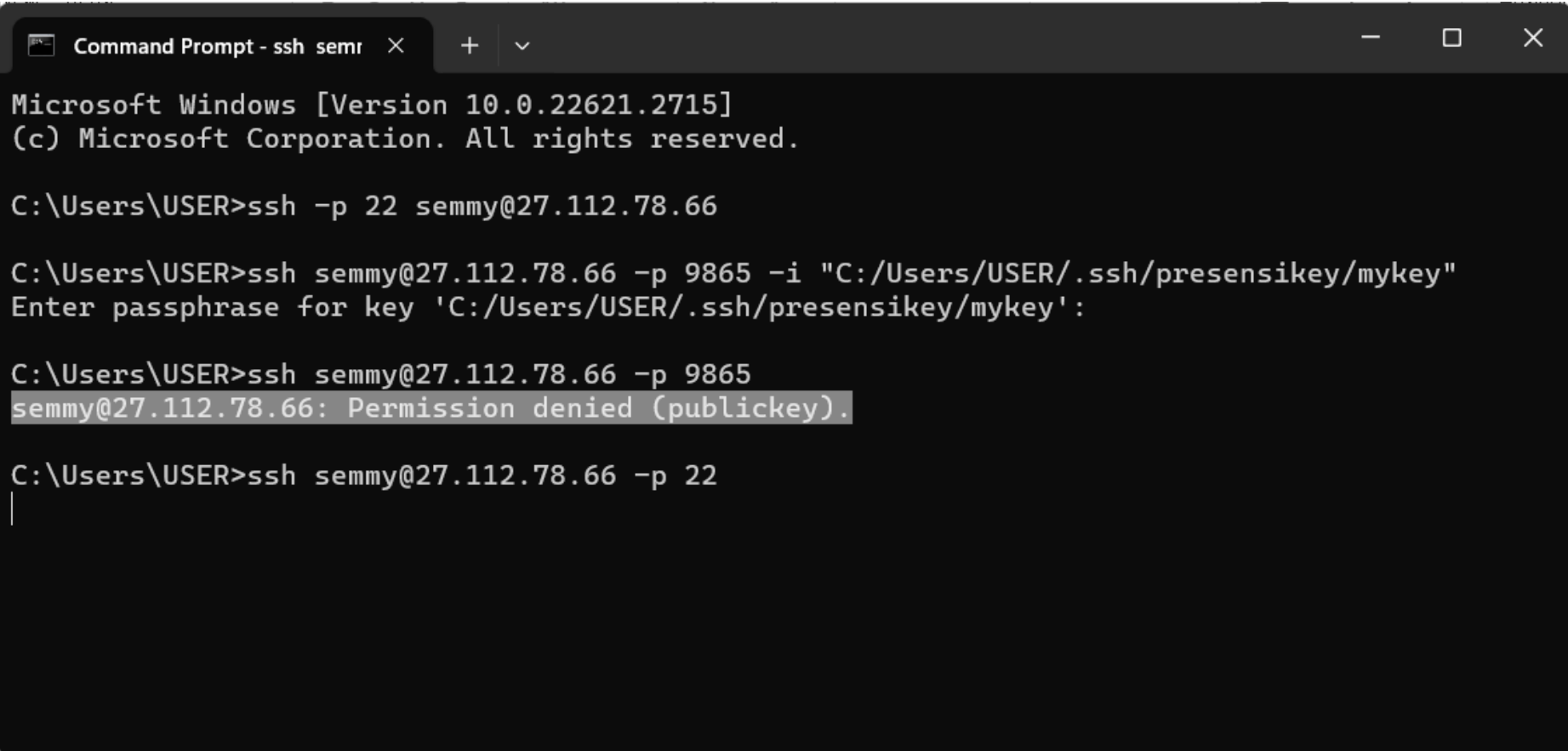
# Authentication:
LoginGraceTime 120
PermitRootLogin prohibit-password
StrictModes yes

RSAAuthentication yes
PubkeyAuthentication yes

[ Read 88 lines ]
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos ^V Prev Page
^X Exit ^R Read File ^E Replace ^U Uncut Text ^I To Spell ^G Go To Line ^U Next Page
```

- 1) Jika *cloud server* tidak bisa dibuka lewat Putty ataupun CMD, maka kalian bisa gunakan virtual console di Idcloudhost.
- 2) Temukan baris yang mengandung Port 22 dan ganti dengan Port 9765 (sesuaikan dengan yang kalian inginkan) dan jangan lupa untuk menghapus “tanda #” di awal dari kata Port.

SSH & Secret Keys



```
Command Prompt - ssh semr  X  +  v
Microsoft Windows [Version 10.0.22621.2715]
(c) Microsoft Corporation. All rights reserved.

C:\Users\USER>ssh -p 22 semmy@27.112.78.66

C:\Users\USER>ssh semmy@27.112.78.66 -p 9865 -i "C:/Users/USER/.ssh/presensikey/mykey"
Enter passphrase for key 'C:/Users/USER/.ssh/presensikey/mykey':

C:\Users\USER>ssh semmy@27.112.78.66 -p 9865
semmy@27.112.78.66: Permission denied (publickey).

C:\Users\USER>ssh semmy@27.112.78.66 -p 22
|
```

END PRESENTATION

Thank you for your attention

Instructor: S – W – T

THANK YOU

